

Asset Management Policy

Policy ID: HH-ISMS-03 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

1. Purpose

You cannot secure what you do not know you have. This policy maintains an accurate inventory of Haritha's hardware, software, and data assets, and assigns each a sensitivity classification that drives handling rules.

Without an inventory, the 2026-08-29 prod DB password drift (LEARNINGS #154) would have been invisible — we'd have been rotating a backup of a stale value. Without classification, every doc gets treated as confidential (paralysis) or as public (leak). This policy fixes both.

Three questions this policy answers:

1. **What do we have?** Hardware, software, data — all listed.
2. **How sensitive is it?** Confidential / Internal / Public.
3. **What do we do when an asset retires?** Secure wipe, documented decommission, audit trail.

2. Scope

2.1 Hardware

Asset	Location	Owner	Notes
VPS host vps-3248b821 (144.217.163.228)	OVH (or current provider)	Venkat	All ERPNext envs + OpenClaw host
Offsite backup VPS	135.125.196.35	Venkat	Receives daily rsync
Local dev laptops	Venkat + admin	Owner	Not used for prod data
Containers (logical assets)	VPS	Venkat	erp-{env}- {backend,frontend,scheduler,redis} per env

2.2 Software

- **Frappe** v16 (vendored in apps/frappe/, do NOT modify per repo guidelines).
- **ERPNext** v16 (vendored, do NOT modify).
- **HRMS** v16 (vendored, do NOT modify).
- **haritha_hospital** custom app (apps/haritha_hospital/) — the only code we own.
- **Nginx** (in erp-prod-frontend-1 and similar) — Let's Encrypt cert handling.
- **MariaDB** 10.x (in erp-{env}-db-1).
- **Redis** (queue + cache).
- **Gunicorn** (WSGI, with --preload — see LEARNINGS #153).
- **Certbot** (Let's Encrypt renewal).

2.3 Data

See §3.2 for classification. Inventory of data categories:

- Patient registration + visit records (PHI).

- Employee master + HR records (PII).
- Attendance, shift, roster (operational PII).
- Payroll + compensation (highly sensitive PII).
- Sales / billing / financial transactions.
- App configuration (hooks, custom fields, print formats, notifications).
- Audit logs (tabVersion, nginx logs, bench logs).
- Source code (haritha_hospital app).
- Backups (tarballs in frappeclaw-data + offsite).
- Documentation (this very file).

3. Policy Statement

3.1 Inventory

1. **Single source of truth.** Asset inventory lives in docs/phase6/09-compliance/asset-inventory.md (to be created — see §6 exceptions for the stub status).
2. **Every new asset is registered within 7 days** of acquisition, provisioning, or creation. This includes new containers, new apps, new domains, new DBs, new laptops.
3. **Every retired asset is marked RETIRED with date + reason + decommission evidence** (e.g., wipe-complete-2026-08-29.txt). Rows are not deleted — historical inventory is audit-relevant.
4. **Annual inventory audit.** Venkat walks the inventory end-to-end, verifies each asset exists (or was properly retired), and re-signs the doc.

3.2 Classification

We use three levels. When in doubt, classify up.

Confidential Patient-identifiable health information (PHI), employee compensation, credentials, audit logs.

Examples: - tabPatient, tabPatient Encounter, tabPatient Medical Record. - tabSalary Slip, tabSalary Structure (net pay, components, bank account). - DB root passwords, SSH private keys, API tokens. - tabVersion audit trail (reveals who touched what).

Handling: - Access requires explicit role grant (Healthcare Practitioner, HR Manager, System Manager). - Never copied to local laptops, USB sticks, or unmanaged cloud drives. - Never sent over unencrypted email or Slack DMs. - Backups encrypted at rest (where supported; tracked as future improvement). - Disposal: secure wipe + documented chain of custody.

Internal Default for anything not explicitly Confidential or Public. Operational data, app configuration, runbooks, code.

Examples: - Attendance (tabAttendance), Shift Assignment, Roster. - App code (apps/haritha_hospital/). - Custom fields, property setters, print formats. - Runbooks (docs/phase6/04-runbooks/*), this policy set. - Bench + nginx logs.

Handling: - Access requires Haritha-team membership (current or former). - May be shared with vendors under NDA (e.g., for support). - Code may live in GitHub (private repo). Runbooks are public-on-GitHub for transparency. - Disposal: standard delete is acceptable; archive before delete if the asset has historical value.

Public Anything explicitly published.

Examples: - Marketing copy on haritha.in. - Generic ERPNext documentation not customized for Haritha. - Open-source libraries we depend on (Frappe, ERPNext upstream code).

Handling: - No restrictions. - Verify nothing Confidential is accidentally attached before publishing.

3.3 Labeling

1. **Documents** in docs/ get an inline classification footer in the first 50 lines: > ****Classification:**** Confidential | Internal | Public Skip only when the doc is a public-facing user manual.
2. **Database tables** are classified in asset-inventory.md (no per-table labels in MariaDB — relies on RBAC).
3. **Backups** are treated as Confidential regardless of source classification, because aggregate dumps magnify sensitivity.
4. **Source code** is Internal by default; specific files (e.g., a config with credentials) override to Confidential.

3.4 Disposal

1. **Hardware.** Vendor-provided secure wipe (e.g., hdparm --security-erase for SSDs, or physical destruction). Wipe evidence retained for 3 years.
2. **Containers.** docker rm is insufficient — anonymous volumes persist. Use docker volume rm or docker-compose down -v only when the contained data is intentionally disposable (see LEARNINGS #154 for the destructive footgun).
3. **Database tables.** DROP TABLE only after confirming the data is migrated to the successor schema. Retain backups per 04.3 Disaster Recovery retention rules.
4. **Backups.** Old tarballs are deleted via srm or shred on local disk, then removed from offsite (rsync --delete after retention window).
5. **Documents.** Old policy versions archived (do not delete) — superseding version increments, prior versions move to archive/.

3a. Current State (as of 2026-08-29)

Concrete inventory snapshot, what is working, what is a known gap.

What we have TODAY

Category	Asset	Location	Owner	Classification	Status
Hardware	VPS host vps-3248b821	OVH/SO YOU START (or current)	Venkat	Confidential (host shell)	Live
Hardware	Offsite backup VPS	135.125.196.35	Venkat	Confidential (backup data)	Live
Hardware	Venkat dev laptop	Local	Venkat	Internal (no prod data)	Live
Hardware	Local admin laptop	Local	PA	Internal (no prod data)	Live
Container	erp-prod- {backend,frontend,scheduler,redis,db,prod}	VPS	Venkat	Confidential (prod data)	Live

Category	Asset	Location	Owner	Classification	Status
Container	erp-dev- {backend,frontend,scheduler,redis,db,proxy}-1	VPS	Venkat	Internal	Live
Container	erp-qa- {backend,frontend,scheduler,redis,db,proxy}-1	VPS	Venkat	Internal	Live
Container	frappeclaw compose tree	VPS /home/vijay/frappeclaw/	Venkat	Confidential (compose env)	Live
Container	frappeclaw- data workspace	VPS /home/vijay/frappeclaw/frappeclaw- data/ workspace	Venkat	Confidential (workspace)	Live
Software	Frappe v16 (vendored)	apps/frappe/	Frappe upstream	Internal (vendored)	Frozen (do not modify)
Software	ERPNext v16 (vendored)	apps/erpnext/	ERPNext upstream	Internal	Frozen
Software	HRMS v16 (vendored)	apps/hrms/	HRMS upstream	Internal	Frozen
Software	haritha_hospital custom app	apps/haritha_hospital/	Venkat	Internal (own code)	Live, evolving
Software	Nginx (TLS termination)	erp-prod-frontend-1	Venkat	Confidential (cert keys)	Live
Software	Certbot (Let's Encrypt)	VPS host	Venkat	Confidential (ACME account)	Live
Software	MariaDB 10.x	erp-{env}-db-1	Venkat	Confidential (DB contents)	Live
Software	Redis	erp-{env}-redis-1	Venkat	Internal (cache/queue)	Live
Software	Gunicorn (--preload)	erp-{env}-backend-1	Venkat	n/a (process)	Live (LEARNINGS #153 awareness)
Data	Patient records (tabPatient*)	pberpprod DB	Venkat	Confidential	Live
Data	Employee records (tabEmployee, tabSalary Slip)	pberpprod DB	Venkat	Confidential	Live
Data	Custom app code + fixtures	GitHub venkat-narasimha/haritha-hospitals (private)	Venkat	Internal	Live
Data	Local backups	/home/vijay/backups	Venkat	Confidential (tarball aggregates)	Live
Data	Offsite backups	venkat@135.125.196.135:/home/venkat/berp_live/backups/	Venkat	Confidential	Live

Category	Asset	Location	Owner	Classification	Status
Data	Runbooks + policies	docs/phase6/{04,09}/	Venkat	Internal	Live
Data	Audit logs	frappe-bench/logs/*.log, nginx access log, /var/log/auth.log	Venkat	Confidential (reveals who-touched-what)	Live
Documentation	This policy set	docs/phase6/09/compliance/	Venkat	Internal	v1.0
Domain	pberpPROD.duckdns + OVH	duckdns + OVH	Venkat	n/a (DNS)	Live
Domain	pberpDEV.duckdns + OVH	duckdns + OVH	Venkat	n/a	Live
Domain	pberpQA.duckdns + OVH	duckdns + OVH	Venkat	n/a	Live

What is WORKING

- **Container naming is consistent.** Every env follows `erp-{env}-{role}-{instance}` — easy to grep, easy to inventory, easy to script against.
- **App vendoring boundary is enforced.** `apps/{frappe,erpnext,hrms}/` are vendored; we never modify them. Only `apps/haritha_hospital/` is owned. This is what makes bench update safe and what allows the customizations to survive upstream upgrades.
- **Backup tarballs follow 3-2-1** (local + offsite, two media, one offsite) — since the 2026-08-19 verification (LEARNINGS #79, #80).
- **Audit logs are populated.** `tabVersion` is populated on every doc save; nginx logs are rotated daily; `frappe-bench/logs/*.log` are rotated by Frappe framework.
- **Runbooks are versioned alongside code** in the same repo. Drift between “what we said we’d do” and “what the script does” is caught at PR review.

Known GAPS

1. **No formal asset-inventory.md doc.** This policy table is the closest thing; the doc-level inventory is in the §6 Exceptions block. Will be authored next batch. Risk: low (Venkat has the inventory in his head); documentation risk: medium (auditor would flag).
2. **No encrypted backups at rest.** Tracked as future in 04-cryptography §3.6.
3. **No column-level encryption** for `tabSalary Slip.net_pay` or patient diagnosis fields.
4. **No per-document classification footer.** The policy mandates the footer in the first 50 lines (see §3.3.1), but the existing runbooks and policies were authored before the rule and need a backfill pass.
5. **Disposal evidence for retired assets is incomplete.** We have no record of `wipe-complete-*.txt` for assets retired before 2026-Q3. Risk: low (those assets are out of service); documentation risk: medium.
6. **No hardware-asset tracking for USB sticks, external SSDs, etc.** We have a “no USB” policy (01-info-security §3.5), so the asset count should be zero, but it isn’t formally asserted.
7. **apps.txt vs apps/ folder drift** is a recurring risk (LEARNINGS #80, #89). No automated reconciliation; relies on Venkat + heartbeat catching `RestartCount > 0` on the scheduler container.

These gaps are explicit v1 scope decisions. The point of listing them is transparency, not apology.

3b. Concrete Examples (Haritha history)

Real asset-management incidents and near-misses that shaped this policy.

Example 1 — 2026-08-29 prod DB password drift = inventory rot symptom (LEARNINGS #154)

- **What happened.** Production DB password in MEMORY.md was stale. The container env had the truth; the doc did not.
- **Root cause.** MEMORY.md was treated as an authoritative inventory of credentials. It is not — it is a snapshot from a previous ops session.
- **Response.** Quarterly verification of container env vars is now policy (§5 of 04-cryptography). MEMORY.md gets a CAUTION: literals may be stale banner.
- **Asset-management lesson.** Inventory rot is a classification problem. The DB password is a credential (Confidential, per §3.2 of this policy). If the inventory of credentials is allowed to drift from the source of truth, the inventory is not an inventory — it's folklore. This is exactly what §3.1.1 ("Single source of truth") is supposed to prevent; the LEARNINGS #154 incident shows the rule was needed.

Example 2 — 2026-08-18 backup recovery + the asset that almost wasn't

- **What happened.** When the silent-backup streak (2026-08-10..18) was discovered, the immediate question was "do we have a clean backup to restore from?". Answer: no. The offsite rsync target was empty. The local backups were 8 days stale.
- **Root cause.** Two backup scripts (prod_backup.sh, dev_backup.sh) shared a race-prone pattern that silently failed for 8 days. The "backup asset" (the offsite rsync target) was nominally live but functionally empty.
- **Response.** Backup scripts retrofitted with timeout 900, exit-code capture, stderr tee, and apps.txt reconciliation (LEARNINGS #79, #80, #113). Verification: 2026-08-19 slot #1 + #2 both PASSED. Asset now has a positive-probe check (offsite backup freshness $\leq$ 26h lag).
- **Asset-management lesson.** "Asset exists" is not "asset is healthy". Inventory must include health, not just presence. This is why §5 of 01-info-security lists "Offsite backup freshness $\leq$ 26h lag" as a KPI — the asset is registered AND its health is asserted daily.

Example 3 — 2026-08-29 unicorn outage = container-asset boundary confusion (LEARNINGS #153)

- **What happened.** bench install-app haritha_hospital succeeded but HTTP requests failed. The "asset" (the haritha_hospital app) was installed; the running process didn't see it.
- **Root cause.** Unicorn --preload freezes sys.path; new apps are invisible until container restart. The asset was correctly registered (in apps.txt, in installed_apps) but the running container was a stale view of the asset inventory.
- **Response.** docker restart erp-{env}-backend-1 post-install is now mandatory.
- **Asset-management lesson.** Container-as-asset has a "warm vs cold" distinction that traditional asset inventories don't capture. A container running stale code is technically the same asset name, but functionally a different asset. §3.1.2 ("Every new asset is registered within 7 days") now has a corollary: every modified asset must trigger a health probe (restart + HTTP 200 check) within the same change window.

Example 4 — 2026-08-08 HRMS Shift Type last_sync_of_checkin = data-asset schema gap (LEARNINGS #42, #43)

- **What happened.** HRMS Shift Type requires last_sync_of_checkin to be set on creation, or the shift silently doesn't pick up employee check-ins. Also, Shift Assignment doesn't retroactively re-tag tabEmployee Checkin.shift — old check-ins stay unattributed.
- **Root cause.** HRMS framework data-contract assumption. Custom apps that don't know about it get silent gaps.
- **Response.** haritha_hospital now sets last_sync_of_checkin in Shift Type creation hooks; backfill script authored to re-tag historical check-ins.
- **Asset-management lesson.** Data assets have schema contracts that aren't always enforced by the DB. Inventory must capture "what fields are required at creation" for each DocType. This is part of the future asset-inventory.md doc (§6 Exceptions).

Example 5 — 2026-08-08 partial-install residue = retired-but-not-decommissioned assets (LEARNINGS #98)

- **What happened.** bench install-app failures left Module Def rows + DocTypes behind. Future bench install-app runs saw these orphans and either crashed or ignored them.
- **Root cause.** Partial-failure assets are not automatically decommissioned.
- **Response.** bench install-app --force is the canonical recovery; orphan rows are cleaned manually.
- **Asset-management lesson.** Retired assets need explicit decommission, not just "marked as gone". This is exactly what §3.1.3 says ("Every retired asset is marked RETIRED with date + reason + decommission evidence"). The LEARNINGS #98 case shows the rule was needed.

Example 6 — 2026-08-08 vendored Frappe + frontend.bundle.js non-existence (LEARNINGS #99)

- **What happened.** A runbook referenced frontend.bundle.js as the asset to verify post-build. Frappe v16 doesn't produce that file — real bundles are at sites/assets/{app}/dist/js/*.bundle.{hash}.js.
- **Root cause.** Documentation drifted from the actual asset layout.
- **Response.** Runbook updated to reference the correct path.
- **Asset-management lesson.** "Asset exists at expected path" is an inventory assertion, not a guarantee. §3.1.4 (annual inventory audit) catches this; runbook reads at PR review should also catch this. The example shows why the annual walk-through matters.

Example 7 — 2026-08-22 SSH key chmod issue = host-level asset state drift (LEARNINGS #93)

- **What happened.** /root/.openclaw/*.key files occasionally lose the 0600 mode after certain operations (e.g., copying between WSL and native Linux). SSH then refuses to use the key.
- **Root cause.** Filesystem mode is a host-level state that drifts.
- **Response.** Periodic chmod 0600 is part of the host bootstrap script.
- **Asset-management lesson.** Host-level state (file modes, key ownership) is asset state. §3.4.1 ("Hardware" disposal) talks about secure wipe; the same discipline applies to "ensure key file is mode 0600" as an asset health assertion.

4. Responsibilities

Role	Responsibilities
Venkat (Owner)	Maintains the inventory doc. Performs annual audit. Approves classification disputes.
Processbricks admin	Approves disposal of Confidential assets. Updates inventory on every provisioning change (new container, new app, new DB). Verifies disposal evidence.
Users	Handle data per its classification. Report mislabeled assets to Venkat. Don't bypass classification for "convenience".
Vendors	Bound by classification rules in their contract. Disposal of Haritha data on vendor hardware follows §3.4.

5. Compliance Measurement

Check	Frequency	Owner	Source
Inventory completeness	Continuous	admin	New-asset registration cadence
Inventory accuracy	Annually	Venkat	Walk-through vs reality
Mislabeled documents	Quarterly	admin	grep + review
Standing Confidential assets without active owner	Quarterly	Venkat	inventory
Disposal evidence completeness	Per disposal	admin	disposal log
Backups classified Confidential	Always	admin	§3.3

KPI target: 100% of assets registered within 7 days of creation. Zero UNKNOWN classifications in the inventory.

6. Exceptions

The `asset-inventory.md` stub is an in-progress exception — current state is “the inventory doc does not yet exist, but every asset is known informally to Venkat”. Resolution: create `asset-inventory.md` in the next batch (or sooner if Venkat prioritizes). Until then, this policy is partially aspirational; classification rules + handling rules apply even without the doc.

Future-improvement exceptions (tracked, not blocking):

- **Encrypted backups at rest.** Current tarballs are unencrypted on local + offsite. Acceptable for v1 (single-operator + offsite is private VPS); revisit if we add a third party to the trust boundary.
- **DLP / labeling enforcement.** Currently relies on humans not misclassifying. Future: pre-commit hook that scans diffs for likely-Confidential patterns (e.g., Aadhaar-like 12-digit numbers, phone numbers in fixtures).

Other exceptions follow the flow in 01-info-security.

6a. Edge Cases & Decision Matrix

Specific scenarios that test the boundaries of asset classification + inventory. Each entry includes the trigger, the decision, and the rationale.

Edge case 1 — A new DocType is added by haritha_hospital; how is it classified?

- **Trigger.** Developer adds a new DocType tabPatient Discharge Summary to the haritha_hospital app.
- **Decision matrix.**

Field on the DocType	Default classification	Why
patient (Link to tabPatient)	Confidential (inherits)	Identifying a patient pulls PHI by reference
discharge_date	Internal	Calendar date alone is not PHI
discharge_medications (Text)	Confidential	Reveals treatment, which is PHI under DPDP Act
discharge_instructions (Text)	Confidential	Free-text clinical note is PHI
summary_pdf (Attach)	Confidential	Aggregated PHI

- **Default action.** Classify the entire DocType as Confidential because at least one field is. Document in asset-inventory.md (when created). RBAC role Healthcare Practitioner (or higher) is required to read.

Edge case 2 — An employee's personal phone number is stored for HR contact

- **Trigger.** tabEmployee has a personal_mobile field used for HR emergency contact.
- **Decision matrix.**

Aspect	Decision
Classification	Confidential (PII)
Who can read	HR Manager, HR User, the employee themselves
Who can write	HR User (during onboarding), employee (via ESS portal)
Retention	Until employee offboarding + 7 years (Indian labor law)
Disposal	Secure-wipe on archive; do not retain in offsite backups beyond retention window

- **Default action.** Classify as Confidential; restrict RBAC accordingly; ensure backups treat it as Confidential aggregate.

Edge case 3 — A test fixture accidentally contains real patient data

- **Trigger.** Developer copies a tabPatient row from prod into a dev fixture for testing. Now dev has PHI.
- **Decision matrix.**

Action	Allowed?	Why
Keep the fixture, scrub identifying fields	YES (after scrub)	Dev can still test schema; PHI is removed
Keep the fixture as-is	NO	Dev is Internal classification; PHI in dev is a classification violation
Delete the fixture, regenerate synthetic data	YES (preferred)	No risk of scrub mistake
Push the fixture to GitHub	NO (regardless of scrub)	GitHub history is forever; can't guarantee future scrub will catch all fields

- **Default action.** Delete and regenerate. Never commit a fixture with real PHI, even with the best scrub intentions.

Edge case 4 — A retired VPS is to be decommissioned

- **Trigger.** Offsite backup VPS is being replaced (provider change, hardware refresh). Old VPS still has 30 days of backups.
- **Decision matrix.**

Step	Required?
Copy latest backup tarball to new VPS before decommission	YES
Verify rsync from new VPS works	YES
Run srm or shred on the old VPS backup directory	YES
Retain wipe-complete-YYYYMMDD.txt evidence for 3 years	YES
Decommission old VPS via provider's "destroy disk" feature	YES (in addition to software wipe)
Power off old VPS without wiping	NO

- **Default action.** Always software-wipe THEN hardware-destroy. Retain evidence. The new VPS must be in the inventory as the new asset; old VPS gets status RETIRED 2026-MM-DD.

Edge case 5 — A new third-party integration stores PHI in its SaaS (e.g., a teleconsultation vendor)

- **Trigger.** Hospital signs a contract with a teleconsultation vendor. Vendor stores session recordings + transcripts (PHI).
- **Decision matrix.**

Aspect	Decision
Classification of vendor data	Confidential (vendor inherits our classification by contract)
Inventory entry	Add to asset-inventory.md as a Vendor: SaaS row with classification + data category + retention + sub-processor list

Aspect	Decision
Contract clause	Required: data residency in India, DPA-compliant sub-processors, breach notification within 24h, right to audit
Backup	Vendor-managed; we require evidence of their backup posture
Disposal	On contract end: vendor provides disposal certificate within 30 days

- **Default action.** Add to inventory. Require contractual classification inheritance. Never let a vendor store Confidential data without an inventory row + a DPA.

Edge case 6 — A backup tarball is discovered to contain a misclassified doc (e.g., a salary slip in a “Internal” backup set)

- **Trigger.** Quarterly audit finds a backup tarball that should have been Confidential-only but contains some Internal-only docs.
- **Decision matrix.**

Action	Why
Treat the tarball as Confidential regardless	Backups are Confidential by default (per §3.3.3); mixed content doesn’t downgrade classification
Investigate root cause	Why was the doc in an Internal set? Was it the wrong backup job? Was it a misclassified upload?
Fix the classification of the doc	Update <code>tabDocType._classification</code> or the RBAC role
Re-run the backup	So the corrected classification is reflected in subsequent tarballs
Document the incident	In the audit log; no public disclosure needed (no leak occurred)

- **Default action.** Default-up (treat as Confidential); investigate root cause; reclassify the source doc.

Edge case 7 — A new container image is pulled (e.g., `frappe/erpnext:v16.5.1`)

- **Trigger.** `docker pull frappe/erpnext:v16.5.1` for a bench upgrade.
- **Decision matrix.**

Aspect	Decision
Inventory entry	Add as a Software row with version + pulled date
Classification	Internal (vendored upstream code)
Vendor	Frappe / ERPNext upstream
Verification	<code>docker inspect</code> for digest; <code>docker scan</code> for known CVEs (when available)
Rollback plan	Keep previous version’s image tagged locally for 30 days

Aspect	Decision
Decommission	After 30 days + new version proven stable, prune old image

- **Default action.** Inventory before deployment. Pin by digest, not tag. CVE-scan before promoting to prod.

7. Related Documents

- 01-info-security.md — Umbrella + exception flow.
- 02-access-control.md — RBAC roles map to classification.
- 04-cryptography.md — Encryption of Confidential data in transit + at rest.
- ../04-runbooks/04.3-disaster-recovery.md — Backup retention rules.
- ../../../../MEMORY.md — Container / env inventory + credential locations.
- ../../../../.learnings/LEARNINGS.md — Lesson #154 (DB password drift = inventory rot symptom).

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial
1.1	2026-08-29	venkat-narasimha	Added §3a Current State (full asset table), §3b Concrete Examples (7 incidents cross-linking LEARNINGS #42, #43, #79, #80, #93, #98, #99, #113, #153, #154), §6a Edge Cases & Decision Matrix (7 scenarios).

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ☐ **Author docs/phase6/09-compliance/asset-inventory.md** — every row from §3a Current State table + classification column + last-reviewed date + deprovisioning status. Owner: VN. Target: 2026-09-05. Status: Not Started.
- ☐ **Backfill classification footers** in all existing docs in docs/phase6/{04,05,07,08,09}/ (first 50 lines per §3.3.1). Owner: VN. Target: 2026-09-12. Status: Not Started.
- ☐ **Add CI step that greps fixtures for likely-PHI patterns** (Aadhaar 12-digit, phone 10-digit, debit 16-digit). Owner: PA. Target: 2026-09-12. Status: Not Started.

Short-term (2026-Q3)

- ❑ **Pre-commit hook** that scans staged diffs for likely-Confidential patterns (per §6 future-item). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ❑ **Author a wipe-complete-*.txt template** + checklist for hardware/software disposal. Owner: VN. Target: 2026-09-30. Status: Not Started.
- ❑ **Audit existing test fixtures** for real PHI residue (per Edge Case 3). Owner: VN. Target: 2026-09-30. Status: Not Started.
- ❑ **Document haritha_hospital DocType classification matrix** — every DocType, every field, default classification. Owner: VN. Target: 2026-10-15. Status: Not Started.
- ❑ **Add a “no USB / no personal device” assertion** to onboarding + annual training. Owner: VN. Target: 2026-10-15. Status: Not Started.

Medium-term (2026-Q4)

- ❑ **Implement automated apps.txt ↔ apps/ folder reconciliation** (LEARNINGS #80, #89). Owner: PA. Target: 2026-11-15. Status: Not Started.
- ❑ **Add RestartCount > 0 heartbeat alert** for all erp-*-scheduler-1 containers (catches drift before next deploy). Owner: PA. Target: 2026-10-31. Status: Not Started.
- ❑ **Vendor onboarding checklist** for any third-party SaaS storing PHI (per Edge Case 5). Owner: VN. Target: 2026-11-15. Status: Not Started.
- ❑ **Annual inventory audit** (per §3.1.4) — first cycle Q4 2026. Owner: VN. Target: 2026-12-15. Status: Not Started.

Long-term (2027+)

- ❑ **Encrypted backups at rest** (cross-link to 04-cryptography §3.6 future). Owner: VN. Target: TBD. Status: Not Started.
- ❑ **Column-level encryption** for tabSalary Slip.net_pay + patient diagnosis fields. Owner: VN. Target: TBD. Status: Not Started.
- ❑ **Hardware asset tracker** (USB sticks, external SSDs, retired laptops) with secure-wipe history. Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (runs forever)

- ❑ **Daily heartbeat:** probe scheduler RestartCount == 0. Owner: PA. Frequency: daily. Status: Done.
- ❑ **Weekly docker image prune -a** (LEARNINGS #91). Owner: PA. Frequency: weekly. Status: Done.
- ❑ **Monthly backup verification** (sanity query on restored DB). Owner: PA. Frequency: monthly. Status: Done.
- ❑ **Quarterly git grep for likely-Confidential patterns** (password=, token=, BEGIN.*PRIVATE KEY, Aadhaar 12-digit). Owner: VN. Frequency: quarterly. Status: Done.
- ❑ **Annual inventory walk-through** (verify every asset exists or is properly RETIRED). Owner: VN. Frequency: annually. Status: Not Started (first cycle Q4 2026).
- ❑ **Annual policy review** (re-read, increment version). Owner: VN. Frequency: annually. Status: Done (this revision).